PORTAFOLIO INTEL

Agente IA Financiero: Arquitectura y Seguridad

Controles de acceso, herramientas de solo lectura y diseño RLS

El problema: Datos vs. Privacidad

Riesgos del enfoque tradicional

Exposición de secretos

Un LLM conectado directamente puede exponer claves al cliente.

Fuga de datos

Riesgo de mezclar contextos entre organizaciones.

Inyecciones de prompt

Documentos externos podrían introducir instrucciones maliciosas.

Arquitectura en 3 capas

1. Cliente autenticado

Envía intención y contexto sin exponer secretos.

2. Edge Function Guardián

Valida permisos y limita accesos a solo lectura.

3. Modelo IA Aislado

Recibe contexto mínimo y devuelve respuestas estructuradas.

> **No queremos que el cliente consulte la BD completa ni que la API key llegue al navegador.**

Arquitectura del Agente IA

1. Cliente Autenticado

Inicia la petición desde la interfaz de usuario (UI).

- Envía intención (prompt)
- Envía contexto de sesión (JWT)
- Declara ámbito consentido

Petición →

2. Edge Function

Actúa como orquestador y barrera de seguridad (`agent-query`).

- Valida RLS, rol y cuota
- Coordina herramientas R/O

Adaptador SEC | **Adaptador Mercado**

Evidencia →

3. Modelo IA

Procesa los datos y genera la respuesta final.

- Recibe contexto mínimo
- No ejecuta SQL ni APIs
- Devuelve JSON estructurado

Herramientas de solo lectura

CATÁLOGO CERRADO

`resolve_company`

Desambigua ticker, mercado e ISIN. Evita que el agente adivine o asuma una empresa incorrecta.

`get_fundamental_snapshot`

Recupera filings SEC o datos de proveedor comercial. Devuelve métricas reportadas con unidad y moneda.

`get_technical_snapshot`

Proporciona OHLCV ajustado y cálculos técnicos deterministas (SMA, MACD, RSI) basados en series válidas.

`get_portfolio_summary`

Agregado privado de la cartera del usuario. Requiere consentimiento explícito y validación RLS.

Separación estricta de conceptos

El agente debe distinguir siempre entre **Dato Reportado** (filings), **Cálculo Determinista** (fórmulas) e **Hipótesis** (supuestos del usuario).

Políticas RLS y Permisos

JWT Original del Usuario

Se utiliza exclusivamente el token de sesión del usuario para consultar Supabase. Las políticas RLS bloquean el acceso a organizaciones o carteras ajenas.

Restricción de Clave de Servicio

La clave de servicio (Service Role) se reserva para adaptadores y auditoría. **Nunca** se emplea para leer carteras privadas.

Consentimiento Explícito

El agente verifica en backend que el usuario haya aprobado el uso de su cartera antes de adjuntar cualquier contexto privado.

Ejemplo de Política RLS (PostgreSQL)

```
-- Lectura: consulta propia u owner
CREATE POLICY agent_query_runs_read ON
public.agent_query_runs
FOR SELECT TO authenticated
USING (actor_id = auth.uid() OR
public.is_organization_owner(organization_id));

-- Evitar inserciones directas desde
cliente
CREATE POLICY client_insert_reject ON
public.agent_query_runs FOR INSERT TO
authenticated WITH CHECK (false);
```

Adaptadores de Servidor

Aislamiento de secretos

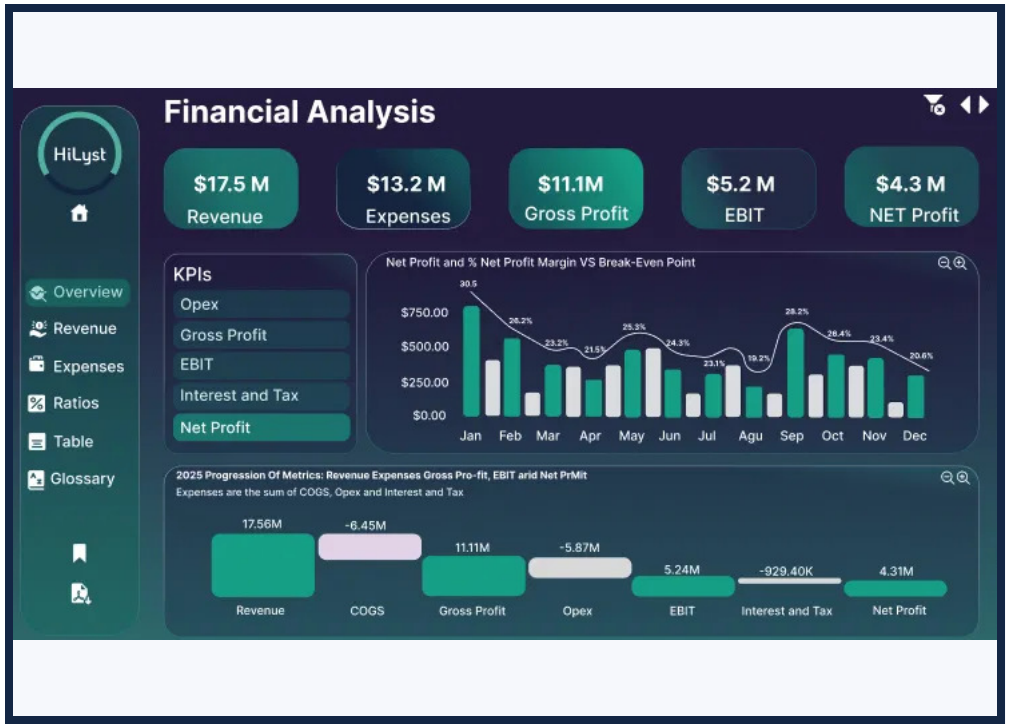
Las API keys de proveedores comerciales (FMP, CoinGecko) residen exclusivamente en el entorno del servidor, nunca se exponen al navegador del usuario.

Control de límites (Rate Limiting)

El adaptador gestiona y respeta estrictamente las cuotas de acceso, como el límite de 10 peticiones por segundo exigido por las políticas de la SEC.

Caché y normalización

Las peticiones repetidas leen directamente desde el snapshot almacenado. Esto reduce drásticamente la latencia, minimiza el coste de API y estandariza el formato de los datos.



INTEGRACIÓN SEGURA DE DATOS

Reglas de Respuesta y Auditoría

Esquema de Respuesta

El modelo debe devolver un JSON estructurado. Toda cifra requiere fuente y fecha de corte.

```
{
  "answer": "...",
  "citations": ["SEC 10-K"],
  "as_of": "2026-08-26",
  "coverage": "120/200 velas",
  "caveats": ["Serie insuficiente"],
  "used_tools": ["get_technical"]
}
```

Registro de Auditoría

Trazabilidad completa de cada consulta sin comprometer la seguridad de los datos.

Intención y Herramientas

Se registra qué herramientas se usaron y el ámbito consentido.

Métricas de Ejecución

Latencia, estado de la consulta y cobertura de las fuentes.

Aislamiento de Secretos

No se guardan API keys, JWTs ni payloads masivos en los logs.

Si la serie es insuficiente, el agente no inventa el dato; declara la limitación en el JSON.

Siguientes pasos



FASE 1

Migraciones RLS

Despliegue de políticas de seguridad, tablas de auditoría y gestión de consentimientos.

FASE 2

Edge Function

Activación de `agent-query` con herramientas de prueba y validación de JSON.

FASE 3

Adaptador SEC

Conexión a EDGAR para el piloto público citado, con caché y control de límites.

FASE 4

Proveedor de Mercado

Selección y licencia comercial para cotizaciones y análisis técnico (OHLCV).

Empezaremos con un **piloto mixto** (datos de cartera autorizada + filings públicos de la SEC) antes de comprometer presupuesto en licencias comerciales de cotizaciones.